

05 – Security (Role-Based Access Control)

Scope: "Role-Based Access Control for Requesters, APPG users, Cost Center Owners, agreed stakeholders, and system administrators." NFR: "enforce role-based access controls to prevent unauthorized access to records, documents, and application functionality."

Security works at **3 levels**:

1. **Entra ID** – who can sign in (security group on the environment).
2. **Dataverse security roles** – which rows a person can read/write (this is the real protection).
3. **Canvas app** – which buttons/screens a person sees (only for user experience, not real security).

1. Create security roles

Go to **Power Platform admin center** → **Environment** → **Settings** → **Users + permissions** → **Security roles**. Tip: **copy** the "Basic User" role, then change it. Add each role to the solution.

Legend: ● Organization (all rows) · ● Business Unit · ● User (own rows / shared) · ✗ none

TVR Requester

Table	Create	Read	Write	Delete	Append	Append To
TV Request	●	●	●	✗	●	●
Request Comment, Request Document	●	●	●	✗	●	●
Feasibility, Funding, Milestone, Risk, Cost	✗	●	✗	✗	✗	✗
Status History	✗	●	✗	✗	✗	✗
Department, Location, Cost Center, Research Institution, Email Template, App Setting	✗	●	✗	✗	✗	●

Result: Priya sees **only her own** requests (plus ones shared with her).

TVR APPG Reviewer

Table	Create	Read	Write	Delete	Append	Append To
TV Request and all child tables	●	●	●	✗	●	●
Master tables	✗	●	✗	✗	✗	●
Notification Log, Error Log	✗	●	✗	✗	✗	✗

TVR Cost Center Owner

Table	Read	Write	Notes
TV Request	●	✗	Sees requests shared with them by the funding flow
Funding Approval	●	●	Can record decision
Child tables	●	✗	via Cascade Share
Master tables	●	✗	

TVR Stakeholder (read only)

Read ● on TV Request + children (only rows shared with them). No write.

TVR Admin

Organization level on everything + master data write + **no delete on TV Request** (retention). System Administrator role is also given to 1–2 IT people.

2. Row-level security – how CCOs and stakeholders see a request

Use an **Access Team** (no coding):

1. Enable **Access Teams** on the TV Request table (Table properties → Advanced → "Have an access team").
2. Admin center → **Access team templates** → **New**: Name `TVR Request Team`, Entity `TV Request`, rights: **Read, Append, AppendTo**.
3. When the funding flow starts, it **adds the Cost Center Owner** to this access team (Dataverse action *Perform an unbound action* → `AddUserToRecordTeam`).
4. APPG adds "agreed stakeholders" from the Request Detail screen (a button that runs the same flow).

Sample: TV-2026-00015 access team = Maria Lopez (CCO), Tom Baker (stakeholder).

3. Assign roles to users (use teams, not individuals)

Admin center → **Teams** → **New team** → Type **Microsoft Entra ID Security Group**:

Dataverse Team	Entra group	Role
TVRMS Requesters	SG-TVRMS-Requesters	TVR Requester
TVRMS APPG	SG-TVRMS-APPG	TVR APPG Reviewer
TVRMS Cost Center Owners	SG-TVRMS-CCOwners	TVR Cost Center Owner
TVRMS Admins	SG-TVRMS-Admins	TVR Admin

Now IT just adds a person to the Entra group → access works automatically.

4. Showing/hiding things in the Canvas app

In `App.OnStart` (or `App.Formulas`), find the user's roles:

```
// App.Formulas (named formulas – recalculated automatically)
CurrentUserRecord = LookUp(Users, 'Primary Email' = User().Email);
IsAPPG = !IsEmpty(Filter(LookUp(Teams, 'Team Name' = "TVRMS APPG").'Users (teammembership_association)',
    'Primary Email' = User().Email));
IsAdmin = !IsEmpty(Filter(LookUp(Teams, 'Team Name' = "TVRMS Admins").'Users (teammembership_association)',
    'Primary Email' = User().Email));
```

Simpler alternative (ASSUMPTION – fine for this size): keep a small **"App Role Member"** table (User + Role). Then: `IsAPPG = !IsBlank(LookUp('App Role Members', User.'Primary Email' = User().Email && Role = 'Role (App Role Members)'.APPG))`

Use it like: `btnApprove.Visible = IsAPPG`.

Remember: hiding a button is NOT security. Dataverse roles are the real security.

5. Security test (sample)

Test	Login as	Expected
Requester sees only own requests	Priya	Sees TV-2026-00015, not TV-2026-00016 (John's)
Requester cannot change status to "Funding Approved"	Priya	Button hidden + Dataverse field security blocks it
CCO sees only shared requests	Maria	Sees TV-2026-00015 after funding flow starts
Stakeholder cannot edit	Tom	Form is read only, save fails
Admin edits master data	Admin	Can add new Cost Center

Field security (optional, stronger): turn on *Column security* for `tvr_status`, `tvr_approvedamount` and give Write only to APPG/Admin profiles.